COBCheck: Pre-Submission Pass for FSE 2027

Sai Krishna Brahmajosyula and Srikrishna Kidambi, Sai Krishna leading | Target: FSE 2027 Research Track | Author order to be decided by Ch

Issued 24 September 2026

TO THE AUTHORS: THIS PAPER CANNOT BE MISSED FOR FSE 2027.

The tool is built, the rules are written, and the related work is strong.

Everything below is about making the evaluation strong enough to carry them.

Core Argument. The draft has a working tool, nine executable article-mapping rules, and a related work section that already differentiates the commercial lineage tooling. What it does not have is evidence. This issue is about strengthening the work rather than trimming it: narrowing the novelty claim so it is defensible, concentrating the evaluation on the four obligations that carry the argument, and building an oracle that a reviewer will trust. The oracle is where the most value is available, because a compliance ground truth is an interpretive artifact and the paper's credibility rests on how it was made.

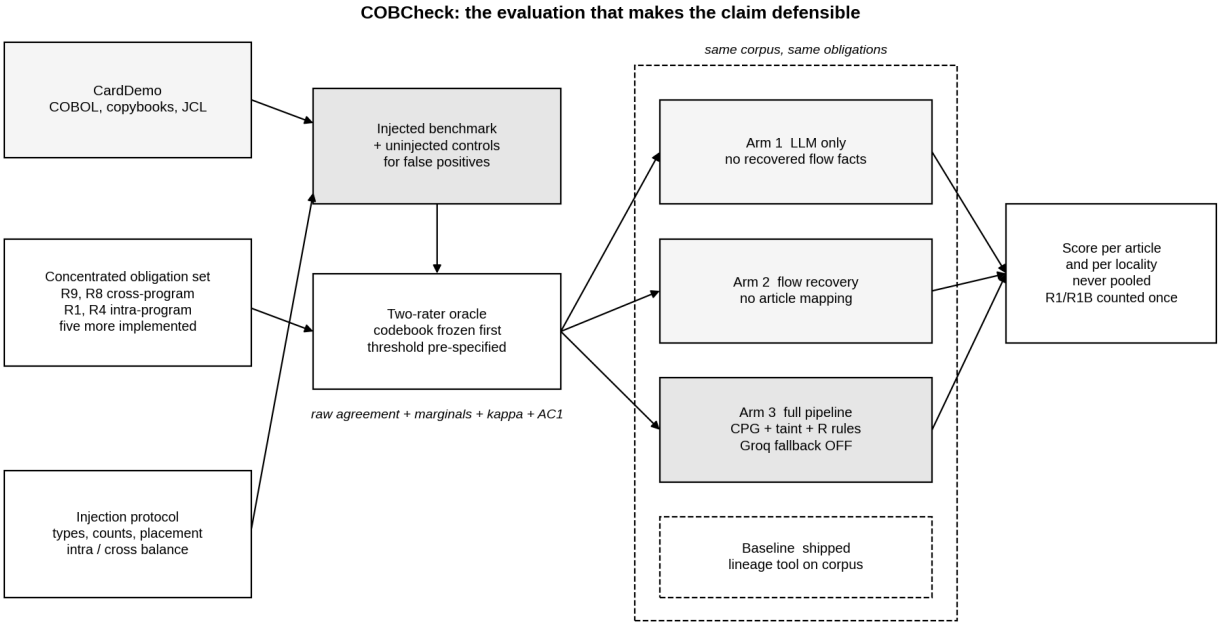


Figure 1. The evaluation that makes the claim defensible. The three inputs on the left are what the draft still needs: a concentrated obligation set, an injection protocol, and the oracle. The dashed enclosure marks what is held fixed across the three arms, the same corpus and the same obligations, which is the control the locality claim rests on. Arm 3 carries a note to disable the Groq fallback, because a model inside the full pipeline would contaminate the contrast with Arm 1. Scoring is per article and per locality, never pooled, with the R1 against R1B counting rule stated in the table itself.

Contributions

1. Article-level attribution of recovered COBOL PII flows to GDPR obligations, as nine executable rules with a stated clearing condition for each. *(the claim)*

Implemented in the draft as Table 1. This is the only contribution a reviewer will score and it is the one with no evidence behind it.

2. The split between obligations that are cross-program by trigger condition and those that are cross-program by evidentiary necessity. *(the falsifiable target)*

R8 requires source and sink programs to differ. R9 requires evidence from both caller and callee and cannot be reduced to a single-program source-to-sink check. This is sharper than the last brief asked for and it is what makes the locality claim testable rather than rhetorical.

3. A COBOL code property graph with CALL, FILE_IO and COPYBOOK edges and a field-sensitive taint engine over it. *(the instrument)*

Now implemented, which closes the question the last two briefs opened with. It is infrastructure, not the headline, and the draft positions it correctly.

4. An injected-violation benchmark over CardDemo with a two-rater oracle. *(the evidence)*

Does not exist yet. Everything above is unscoreable without it.

The Six Questions

What is already strong

• The flow engine runs. ANTLR4 parser, code property graph with CALL, FILE_IO and COPYBOOK edges, field-sensitive taint with group parameter matching across LINKAGE. The question the last two briefs opened with is answered from the code.

• Table 1 is a real contribution. Nine rules, each with a static detection condition and a clearing condition, across Articles 5(1)(c), 5(1)(e), 5(1)(f), 6(1), 6(4), 9, 10, 32 and 44.

• The R8 against R9 split is sharper than the brief asked for. R8 is cross-program by trigger condition; R9 is cross-program by evidentiary necessity and cannot be reduced to a single-program source-to-sink check. That gives the locality claim a falsifiable target instead of a pooled score.

• The absence-of-evidence treatment for lawful basis and retention is legally honest. It reports the absence of a detectable guard rather than asserting unlawfulness, which is the right call and will save an argument with a reviewer who knows the regulation.

• Personal data identification is defined from declarations, names and PIC clauses, which is the part with no analogue in the Android literature.

• Related work differentiates AWS Transform and Micro Focus explicitly, which was the visible gap in the last issue.

Where the novelty claim has to narrow, and why that strengthens it

• Binder and Kunz, Using Static Code Analysis for GDPR Compliance Checks, LNCS 15263, 2025, derive code properties from individual GDPR articles, implement them as queries in a static analysis tool, and evaluate against a novel test suite. That is article-to-code-property mapping, a tool, and constructed ground truth: the same three parts as this paper.

• So the sentence that no published work decides GDPR article-level obligations from source and evaluates that decision against a ground truth is not true as written. It must narrow to COBOL.

• Narrowing makes the paper stronger, not weaker. An unqualified first claim invites a reviewer to find the counterexample. A claim scoped to a language with no API surface, where sources and sinks come from declarations and evidence crosses programs through copybooks, shared files and LINKAGE, is

one nobody can counter.

• Two more from the same group belong in related work. Kunz et al., Using LLMs to Identify Personal Data Processing in Source Code, 2025, which sits on both the PII identification stage and the LLM-only arm. And Banse, Kunz et al.'s Cloud Property Graph, which is the privacy-facing member of the same CPG family already cited through Yamaguchi.

• One correction inside a paper already cited. GDPR-Bench-Android contains Formal-AST, a non-LLM formal baseline for source-code GDPR analysis, which is the analogue of Arm 2 and should be named as such. The same paper also notes that FlowDroid, IccTA and Amandroid operate on compiled APKs rather than source, so the draft should not present them as source-level comparators.

• The commercial side is fine as it stands.

How to make the oracle a strength

• A compliance ground truth is an interpretive artifact, so the paper's credibility rests on how it was built. This is the cheapest place to buy reviewer confidence.

• Who. Two raters who did not write the injection scripts. Neither sees the injection manifest or any tool output.

• Unit. One candidate finding: a data path plus a proposed obligation. Each rater judges it independently.

• Labels. Violation of the named article. Not a violation. Insufficient evidence to decide.

• Materials. The COBOL source of the programs on the path, the copybooks, the data path, and the codebook. The codebook gives, per obligation, the article text, the code-level condition, the clearing condition, and two worked examples, one positive and one negative.

• Order, which is the part that carries the credibility. Freeze the codebook. Pilot on twenty findings independently. Compute agreement, discuss, revise the codebook once if needed, then discard the pilot findings entirely. Main round on the full set, independently, no discussion until every item is labelled.

• Statistics, and report four rather than one: raw agreement, the marginal distribution, Cohen's kappa, and Gwet's AC1.

• The reason for four. The labels will be heavily imbalanced, since most candidate findings are not violations, and that is exactly the condition where kappa collapses while raw agreement stays high. There is a published software engineering case of 95 percent raw agreement yielding only moderate kappa for this reason. Reporting the marginals and AC1 alongside turns a likely embarrassment into a methodological strength.

• Pre-specify the threshold in writing and justify it by what the rating is used for, rather than quoting 0.8 because it is conventional. Report the value obtained whatever it is.

• Disagreements are resolved by a third adjudicator or by consensus after the statistics are computed and recorded. The reported figure is never the post-discussion one.

• Into the artifact: the codebook with its version, both raters' independent label files, the disagreement log, and the adjudicated ground truth.

How to concentrate the evaluation

• Evaluate four obligations rather than nine. Keep R9 and R8, which carry the cross-program claim, and R1 and R4, which give the locality contrast something to contrast against.

• This is a strengthening move rather than a reduction. Annotation cost scales with obligations, so four rules annotated carefully with a defensible agreement figure is worth more at review than nine annotated thinly.

• RQ2 asks where error originates and RQ3 asks whether accuracy splits by locality. Four rules spanning both localities answer both questions. Nine answer them no better.

• The other five stay in the tool and in Table 1, reported as implemented but not evaluated in this study. That is honest, it strengthens the artifact, and it gives the journal extension somewhere to go.

• One application, CardDemo, which is also the corpus the AWS demonstration uses, so the comparison with shipped tooling stands on the same ground. Decide explicitly whether GenApp is in, because it is currently named in the contributions and absent from the methodology.

• Keep uninjected control copies from the start. RQ4's false positive rate needs them and they cost nothing.

Two things that would weaken the result if left alone

• The Groq fallback puts a model inside the PII identification path of the full pipeline. The paper's central comparison is an LLM-only arm against the full pipeline, so a model inside both arms blurs exactly the contrast being measured. Disable it for all experimental runs, or keep it as a separate labelled ablation cell and say so.

• R1 and R1B report the same technical condition under two articles, and so do R4 and R4B. Whether that is one detection or two changes every precision and recall denominator. Decide the rule now and state it in the results table rather than in a footnote, because a reviewer who works it out unaided will assume the favourable choice was made deliberately.

What to fix in the text

• Sections 4.11 and 4.12 are the same section written twice. Keep 4.12, which carries Table 1, and delete 4.11.

• References 5 and 6 are both FlowDroid. References 2 and 16 are both the Khedkar and Bodden paper, and 2 is credited to Anonymous.

• Two references are attributed to Anonymous when both papers have named authors. Venues in this family are desk-rejecting on unverifiable references this cycle.

• The third claim in the introduction is garbled and currently reads as conceding the paper's central point. Rewrite it as a prediction: mapping accuracy may degrade on cross-program flows, and the study measures whether it does.

• RQ2 contains a typo, RD for RQ, and the sentence stating the central claim is inverted.

• The abstract carries a bracketed note to itself about the evaluation. The CCS concepts and keyword blocks are still ACM placeholder text.

• Sections 6 Limitations and 7 Conclusion are empty, and there is no Data Availability section, which the track requires after the Conclusion and which does not count against the page limit.

Worked sentences

• **Narrowed novelty claim, Introduction.** Delete the unqualified sentence and replace it with a claim scoped to COBOL. Keep the word first, but attach it to the property nobody can counter.

Write: “Article-level GDPR compliance analysis has been attempted at source level before, most closely by deriving code properties from individual articles and evaluating them against a constructed test suite. Those approaches operate on languages whose privacy-relevant sources and sinks are API calls with established semantics. To the best of our knowledge, COBCheck is the first source-level GDPR compliance analysis for COBOL, where personal data must be identified from data declarations rather than signatures, and where the evidence for an obligation is frequently distributed across programs through copybooks, shared files, and CALL ... USING interfaces.”

• **Related work, new paragraph before the positioning subsection.** Name Binder and Kunz as the closest work and state the difference in one sentence rather than listing features.

Write: “Binder and Kunz derive code properties from individual GDPR articles, implement them as queries in a static analysis tool, and evaluate the resulting checks against a purpose-built test suite. Their design establishes that article-level obligations can be operationalised as static conditions, which is the premise COBCheck adopts. The difference is the setting: their analysis targets code in which privacy-relevant operations are identifiable from API semantics, whereas in COBOL both the personal-data sources and the sinks must be recovered from declarations, PICTURE clauses and file usage before any obligation can be evaluated.”

• **Related work, same group.** Add the two adjacent papers in one sentence each, and say what each does for this work.

Write: “Kunz et al. use large language models to identify personal data processing in source code, which is the task COBCheck performs from declarations and which our LLM-only arm approximates. The Cloud Property Graph line applies a unified graph representation to security and privacy assessment, and is the privacy-facing antecedent of the code property graph construction we adopt.”

• **Related work, correction on the Android taint tools.** Stop presenting FlowDroid, IccTA and Amandroid as source-level comparators. State what they operate on.

Write: “FlowDroid, IccTA and Amandroid analyse compiled application packages rather than source, which makes them precise on their own terms but not directly comparable to a source-level analysis. We adopt their source-propagation-sink abstraction rather than their artifact.”

• **Related work, Arm 2 antecedent.** Name Formal-AST so the flow-recovery arm has a stated antecedent instead of appearing invented.

Write: “GDPR-Bench-Android introduces Formal-AST as a non-LLM formal baseline for source-level compliance detection. Our flow-recovery arm plays the same role in this study, isolating what recovered structure alone can decide before any obligation is attached.”

• **Introduction, the third claim.** The current sentence concedes the paper's point. Rewrite it as a prediction the study tests.

Write: “Our third expectation is the one we are least certain of. Recovering a flow across a program boundary does not by itself make the obligation easier to attribute, and mapping accuracy may fall on cross-program flows even where recovery succeeds. Whether it does is an empirical question, and separating attribution accuracy from detection accuracy is what allows us to answer it.”

• **RQ2, restated.** Fix the typo and invert the sentence so it states the claim rather than negating it.

Write: “RQ2. When a compliance decision is wrong, does the error originate in flow recovery or in obligation mapping? We score article attribution separately from flow detection, so that a mapping failure is visible as a mapping failure rather than absorbed into an aggregate. This question carries the paper's central claim, that mapping rather than recovery is where correctness in source-level compliance analysis is won or lost.”

• **Evaluation, the R1 against R1B counting rule.** State the rule in the results table caption, not in a footnote. Either choice is defensible; the silence is not.

Write: “Rules R1 and R1B, and likewise R4 and R4B, fire on the same technical condition and report it under two distinct obligations. We count such a pair as a single detection with two article attributions, so that detection precision and recall are not inflated by reporting the same evidence twice. Attribution accuracy is scored separately for each article.”

• **Methodology, the Groq fallback.** Disable it, and say so where a reviewer will look for it.

Write: “The optional language-model fallback in PII identification is disabled for all experiments reported here. The study contrasts an arm with no recovered flow facts against the full pipeline, and a model inside the identification stage of both arms would blur that contrast. All personal-data identification in the reported runs is deterministic.”

• **Evaluation, the agreement report.** Report four figures, and say why in the same paragraph. This is the sentence that buys reviewer confidence.

Write: “Ground truth was constructed independently by two raters against a codebook frozen before annotation began. We report raw agreement, the marginal label distribution, Cohen's kappa, and Gwet's AC1. Kappa alone is unreliable under the label imbalance inherent to injected-violation benchmarks, where most candidate findings are not violations, so the marginals and a coefficient that survives imbalance are reported alongside it rather than in place of it.”

• **Evaluation, the threshold.** Justify the threshold by the use the ground truth is put to, rather than quoting the conventional band.

Write: “We fixed an agreement threshold before annotation began. The threshold was set by the use to which the ground truth is put: it is the reference against which three analysis arms are scored, so a disagreement rate that could reorder the arms would make the comparison meaningless. We report the value obtained regardless of whether it met the threshold.”

• **Evaluation, the obligation scope.** Turn the concentration into a stated design choice rather than something a reviewer notices as a gap.

Write: “COBCheck implements nine rules. This study evaluates four of them, selected to span both evidence localities: two that require cross-program evidence and two decidable within a single program. Annotation effort scales with the number of obligations rather than with the size of the corpus, and we judged a smaller set annotated to a reportable agreement figure more informative than a larger set annotated thinly. The remaining five rules are released in the artifact and are not evaluated here.”

• **Limitations, opening.** Open with the threat a reviewer will raise first, not the weakest one.

Write: “Injected violations may not reflect the distribution of naturally occurring ones. We inject according to a protocol fixed before the corpus was built, with a stated balance between intra-program and cross-program cases, but the resulting distribution is a design choice rather than an observed one. Results should be read as evidence about the analysis under a controlled distribution of defects, not as an estimate of prevalence in production COBOL.”

• **Limitations, the interpretive oracle.** Say plainly what the ground truth is and is not.

Write: “Article attribution is a legal interpretation. Our ground truth records the raters' interpretation under a fixed codebook, not an adjudicated legal determination, and a different codebook could yield a different ground truth. We release the codebook and both raters' independent labels so that this interpretation can be inspected and disagreed with.”

• **Data Availability, after the Conclusion.** Required by the track and outside the page limit. One short paragraph.

Write: “A replication package is available to the programme committee and contains the analysis source, the injection protocol and scripts, the injected corpus with its uninjected controls, the annotation codebook, both raters' independent label files, the disagreement log, the adjudicated ground truth, and all arm outputs. It is hosted anonymously for review and will be released publicly on acceptance.”

What This Stands On

Field	Detail
Base paper	Ferrara, P., Olivieri, L., Spoto, F. Tailoring Taint Analysis to GDPR. Privacy Technologies and Policy, Springer, 2018. Relationship: port. The sentence stood on is that, starting from the policy established by the controller of sensitive data, taint analysis detects potential leakages and the flow is then reconstructed to check whether the flow is allowed. The port is to a language where sources, sinks and the policy binding are not given. Unchanged from the last issue and correctly carried into the draft.
Theoretical basis	Two instruments, and the second is new in this issue. The General Data Protection Regulation as a legal instrument taken at article level, with the obligation set derived from named articles rather than from an intuition about privacy, which is what allows a mapping to be right or wrong. The draft adds the Torre et al. conceptual model as the principle grouping, which is a real improvement. For the oracle, El Emam's Benchmarking Kappa in Empirical Software Engineering is the software engineering reference rather than a borrowed medical one, and it exists to answer the question that follows a kappa value, which is how good is it. Cohen 1960 supplies the statistic and Landis and Koch 1977 the bands, with the caveat stated in the paper that those bands are a 1977 convention and not a derived scale.
Empirical standards	Engineering Research, Benchmarking and Simulation, Sampling supplement

Mapping to the SIGSOFT Empirical Standards

Standard	Why it applies	Where the work currently falls short
Engineering Research	COBCheck is a technique and tool evaluated on a constructed task	No results. No baseline for the flow-recovery arm, since shipped lineage tooling has still not been run on the corpus for comparison
Benchmarking and Simulation	Evidence comes from scoring three arms against an injected-violation benchmark	The benchmark does not exist. Injection protocol unwritten, injection distribution unjustified, no held-out portion defined
Sampling supplement	Programs, data elements and injected violations are all sampled	Sampling frame for which programs and which obligations are covered is undefined. The obligation cut proposed in this issue is the moment to define it

Not applicable, despite appearances. Experiments with Human Participants does not apply, because the two raters construct the oracle and are not study subjects. Repository Mining does not apply, because the corpus is a fixed application rather than a mined population. Case Study does not apply, because the application is an instrument rather than a setting studied in its own right. Qualitative Surveys and Grounded Theory do not apply, because the obligation coding scheme is fixed in advance from the regulation rather than developed from the data.

How It Will Be Evaluated

Metric	Measures	Why this construct	Source	What counts as good
Precision, recall and F1 per obligation	Detection quality against injected ground truth	The standard reporting form for compliance detection benchmarks	GDPR-Bench-Android	Reported per article rather than pooled, since pooling hides the claim. The R1 against R1B double-counting decision is stated in the same table
Article attribution accuracy	Whether the correct obligation is named for a correctly recovered flow	Isolates mapping error from recovery error, which is RQ2 and the paper's central claim	New to this work	Reported separately from detection, so a mapping failure is visible as a mapping failure
Cross-program against intra-program recall	Whether performance splits by evidence locality	RQ3. The claim is about the split rather than the absolute level	New to this work, argued from the R8 and R9 structural split	The LLM-only arm materially lower on cross-program than intra-program, with the full pipeline closing the difference. R9 is the sharpest case because it cannot be reduced to a single-program check
Inter-rater agreement on the oracle	Reliability of the ground truth, reported as raw agreement, the marginal distribution, Cohen's kappa and Gwet's AC1	Every number in the paper rests on an interpretive ground truth, and imbalanced labels make kappa alone misleading	El Emam, Benchmarking Kappa, EMSE 1999. Cohen 1960 for the statistic, Landis and Koch 1977 for the bands, Gwet for the companion statistic that survives imbalance	Threshold pre-specified in writing and justified by the use the rating is put to. All four figures reported, and the value obtained is reported whatever it is
False positives on unmodified programs	Whether the analysis fires on clean code	RQ4. A compliance tool that over-reports is unusable in audit regardless of its recall	Engineering Research standard	Reported on the uninjected control copies, which must be kept from the start

State of the Art and References

• Re-checked in depth for this issue, and the picture changed.

• Binder and Kunz 2025 is the closest work and is not cited. It performs article-to-code-property derivation, implements it as queries, and evaluates against a test suite.

• Kunz et al. 2025 on LLM identification of personal data processing in source code sits on both the PII stage and the LLM-only arm, and is not cited.

• The Cloud Property Graph line from the same group is the privacy-facing CPG work and is not cited.

• Formal-AST inside GDPR-Bench-Android is the analogue of Arm 2 and should be named.

• Commercial COBOL tooling now advertises cross-file taint analysis and data exposure detection tied to GDPR, HIPAA and PCI. The draft's positioning against commercial tools holds and needs no change.

• Still to check once, at writing time: forward citations of the base paper, and whether GDPR-Bench-Android has a published version superseding the preprint.

• Verify every reference resolves to a real retrievable work, and replace the two Anonymous attributions.

Technical Tasks

Task	What to produce	Done when	Cost
Disable the Groq fallback for all experimental runs	A configuration flag and a note in the methodology	The full pipeline contains no model in the PII identification path. If it is kept at all, it is a separate ablation cell and is labelled as one	Low
Profile CardDemo	Program, copybook and JCL counts, personal data element inventory, cross-program call and file dependency map	Inventory reproduces from a script over the checked-out corpus	Low
Build the injected corpus and the uninjected controls	Injected copies, injection manifest, control copies	Manifest and corpus regenerate from the scripts, and the intra against cross balance matches the protocol	Medium
Implement the LLM-only arm	Baseline runner applying an LLM to source without recovered flow facts	Produces article attributions in the same output format as the full pipeline, so the two are directly comparable	Medium
Implement the flow-recovery-only arm	The pipeline run with the mapping layer disabled	Produces recovered flows with no article attached, in a scoreable format	Low
Run a shipped lineage tool over the corpus	Recovered lineage in a comparable format, or a documented statement of why it could not be run	Either the comparison exists or its impossibility is recorded in threats to validity	Medium
Annotate with two raters against the fixed protocol	Labelled ground truth plus the agreement figure	Annotation is complete and the agreement statistic is computed once, from independent labels	High
Score all three arms	Per-article and per-locality results tables, plus the false positive rate on controls	Every metric in the evaluation table is populated or explicitly marked as not applicable	Medium

Research Tasks

1. **MUST. Write the oracle protocol and freeze the codebook before anyone annotates anything.**

   Proposed content, write it as a two-page document in the artifact:

   1. Raters. Two, neither of whom wrote the injection scripts. Neither sees the injection manifest or any tool output at any point.

   2. Unit. One candidate finding, being a data path plus a proposed obligation. Judged independently.

   3. Labels. Violation of the named article. Not a violation. Insufficient evidence to decide.

   4. Materials. The COBOL source of every program on the path, the copybooks, the path itself, and the codebook.

   5. Codebook. For each obligation in scope: the article text, the code-level condition, the clearing condition, one worked positive example and one worked negative example.

   6. Pilot. Twenty findings, both raters independently. Compute agreement, discuss, revise the codebook once if needed, then discard the pilot findings entirely.

   7. Main round. The full set, independently, with no discussion until every item is labelled.

   8. Reported statistics. Raw agreement, the marginal label distribution, Cohen's kappa, Gwet's AC1.

   9. Threshold. Fixed in writing before the main round, justified by the use the ground truth is put to.

   10. Adjudication. A third rater or consensus, applied only after the statistics are computed and recorded.

   11. Released. The codebook with its version, both label files, the disagreement log, the adjudicated ground truth.

2. **MUST. Choose the four obligations to evaluate and record the reasoning.**

   Proposed choice, to be confirmed or replaced with a reason: R9 under Article 5(1)(c), cross-program by evidentiary necessity. R8 under Article 6(4), cross-program by trigger condition. R1 under Article 5(1)(f), intra-program. R4 under Article 5(1)(f), intra-program at an at-rest sink.

   Write, in the evaluation setup: “The four obligations were selected to span both evidence localities and both kinds of cross-program dependence. R9 cannot be decided without evidence from both caller and callee, R8 requires only that source and sink programs differ, and R1 and R4 are decidable within a single program at two different sink kinds. Together they let attribution accuracy be compared across localities without holding the sink kind constant as a confound.”

3. **MUST. Write the injection protocol.**

   Proposed content:

   1. Violation types. One per evaluated obligation, derived from that rule's static detection condition.

   2. Counts. Equal numbers per obligation, so that per-article recall is computed on comparable denominators.

   3. Balance. Half the cross-program obligations injected across a CALL boundary and half across a shared file, so locality is not confounded with mechanism.

   4. Placement. Candidate sites enumerated by a script over the code property graph, then sampled, so placement is not chosen by hand.

   5. Negative controls. Uninjected copies of every program retained from the start, for the false positive rate in RQ4.

   6. Manifest. Every injection recorded with its site, type, obligation and locality, and the whole corpus regenerable from the scripts.

   Write, in the methodology: “Injection sites were enumerated automatically from the code property graph and sampled, rather than selected by hand, so that the placement of violations is independent of the analysis being evaluated.”

4. **Rewrite the novelty claim and extend related work.** Replacement text for the claim, the Binder and Kunz paragraph, the two adjacent Kunz papers, the Android taint correction and the Formal-AST antecedent is given in full in the Worked Sentences section.

5. **Decide the R1 against R1B counting rule.** Replacement text for the results table caption is in the Worked Sentences section. Bring the alternative and its effect on the numbers before adopting it.

6. **Decide whether GenApp is in scope.**

   If out, write: “We evaluate on a single application, AWS CardDemo, which is also the corpus used in the vendor demonstration of cross-program lineage recovery, so that our comparison with shipped tooling is made on the same code. Generalisation across applications is left to future work.”

   If in, the methodology must state the second corpus, its size, and whether the obligation set and injection counts are held identical across both. Do not leave GenApp named in the contributions and absent from the methodology.

7. **Write Sections 6 and 7 and add Data Availability.** Opening paragraphs for both limitations and the full Data Availability statement are in the Worked Sentences section. Section 7 should state the result, the boundary of the claim, and the one thing the study could not settle.
8. **Fix the introduction's third claim and RQ2.** Replacement text for both is in the Worked Sentences section.
9. **Clean the bibliography.**
   Specifically: delete one of the two FlowDroid entries, currently 5 and 6. Merge entries 2 and 16, which are the same Khedkar and Bodden paper. Replace the Anonymous attribution on entry 2 with Khedkar, M. and Bodden, E. Replace the Anonymous attribution on entry 3 with the GDPR-Bench-Android author list. Verify every remaining entry resolves to a retrievable work.

Ordering and Dependencies

• The codebook and the obligation choice block annotation, and annotation blocks every number in the paper.

• The injection protocol blocks the benchmark build, and the benchmark blocks the arm runs.

• The corpus profile comes early, because a late profile invalidates an injection balance already built against it.

• Disabling the Groq fallback comes before any arm is run, since a run with it enabled is not comparable to one without and would have to be repeated.

• Annotation runs in parallel with the arm runs. The raters and the tool do not compete for the same hands.

• The writing and positioning tasks depend on nothing and belong in the window while annotation runs.

Decisions to make

1. Propose the four obligations to evaluate, with the reason each was chosen and what is lost by leaving the other five unevaluated. Bring the alternative of evaluating all nine with the annotation cost attached.
2. Propose the pre-specified agreement threshold and the justification for it, drawn from what the ground truth is used for rather than from convention.
3. Propose the R1 against R1B counting rule, with what each choice does to reported precision and recall, and which a reviewer is more likely to accept.
4. Propose whether GenApp is in scope, with the cost of adding it against the value of a second application.
5. Propose whether the Groq fallback is dropped outright or retained as a labelled ablation cell, and what the ablation would show if retained.

Revision history

Issue	What changed
24 September 2026	Pre-submission pass against the 24 September draft, written as bullets and focused on strengthening the current work. Adds the Binder and Kunz line as the closest work and narrows the novelty claim to COBOL. Adds the full oracle procedure with El Emam as its base paper and a four-statistic treatment for imbalanced labels. Concentrates the evaluated obligation set on the four rules that carry the argument. Adds a worked-sentences section giving the exact replacement text for each change.
6 September 2026	Reissued on the article-mapping framing after the state of the art check found cross-program lineage on COBOL shipped and demonstrated on CardDemo. Corpus recorded as CardDemo and GenApp with injected violations. Target moved to FSE 2027.
April 2026	First issue, covering COBCheck and COBSmell together, with a Z-COBOL and GnuCOBOL corpus and an ICSE 2027 target. Retired rather than replaced.

References

1. Ferrara, P., Olivieri, L., Spoto, F. Tailoring Taint Analysis to GDPR. Privacy Technologies and Policy, Springer, 2018.
2. Binder, A., Kunz, I. Using Static Code Analysis for GDPR Compliance Checks. LNCS 15263, 2025. Closest work. Not currently cited.
3. Kunz, I., Kao, C.-Y., Kowatsch, D., Bettinger, K. Using LLMs to Identify Personal Data Processing in Source Code. 2025. Not currently cited.
4. Banse, C., Kunz, I., Schneider, A., Weiss, K. Cloud Property Graph: Connecting Cloud Security Assessments with Static Code Analysis. IEEE CLOUD 2021. Not currently cited.
5. GDPR-Bench-Android: A Benchmark for Evaluating Automated GDPR Compliance Detection in Android. arXiv:2511.00619. Contains Formal-AST, the analogue of Arm 2. Cited as Anonymous in the draft.
6. Khedkar, M., Bodden, E. Toward an Android Static Analysis Approach for Data Protection. arXiv:2402.07889, 2024. Cited twice in the draft, once as Anonymous.
7. El Emam, K. Benchmarking Kappa: Interrater Agreement in Software Process Assessments. Empirical Software Engineering 4(2), 1999. Base paper for the oracle method.
8. Cohen, J. A Coefficient of Agreement for Nominal Scales. Educational and Psychological Measurement 20(1), 1960.
9. Landis, J. R., Koch, G. G. The Measurement of Observer Agreement for Categorical Data. Biometrics 33(1), 1977.
10. Gwet, K. L. Computing Inter-Rater Reliability and Its Variance in the Presence of High Agreement. British Journal of Mathematical and Statistical Psychology 61(1), 2008.
11. Yamaguchi, F., Golde, N., Arp, D., Rieck, K. Modeling and Discovering Vulnerabilities with Code Property Graphs. IEEE S&P; 2014.
12. Torre, D., Alferez, M., Soltana, G., Sabetzadeh, M., Briand, L. Modeling Data Protection and Privacy: Application and Experience with GDPR. SoSyM 20(6), 2021.
13. European Parliament and Council. Regulation (EU) 2016/679, General Data Protection Regulation.
14. FSE 2027 Research Papers call for papers. Evaluation criteria, double-anonymous policy, and the Data Availability requirement.

AI Disclosure

The original ideas, analysis, and research synthesis in this report are the intellectual contribution of the authors. AI-assisted tools were used to enhance the clarity and presentation of the writing.